LootMarket

Marketplace P2P de gaming — aplicación de los TPs de Base de Datos

Equipo 01 · Curso Merlino (FIUBA) · Documento conceptual

> LootMarket es un marketplace peer-to-peer de cuentas, skins, ítems y claves de activación, con **escrow** (retención del pago hasta confirmar la entrega), historial de operaciones auditable y resolución de disputas. El proyecto integra los temas de los TP 1 a 8: cada uno se aplica a un problema concreto del negocio, no como ejercicio aislado.

TP1 · Patrón de acceso a datos (Repository)

Centralizar toda la persistencia en una sola capa.

El acceso a la base se concentra en una capa de repositorios que la tratan como una colección de objetos. La lógica de negocio nunca habla con la base directamente.

Para qué: separar negocio de persistencia, evitar SQL disperso y dejar un único lugar responsable de los datos — más mantenible y testeable.

TP3 · Control de acceso: RBAC vs. ABAC

Combinar control por rol con control por atributos.

- **RBAC** (por rol) en la aplicación: cada acción exige un rol mínimo (comprador, vendedor, moderador, admin).
- **ABAC** (por atributos) en la base, con Row Level Security: el acceso a datos sensibles evalúa atributos del *sujeto*, del *recurso* y del *entorno*. El rol por sí solo no alcanza.

Para qué: defensa en profundidad. Aunque la aplicación falle, la base sigue restringiendo el acceso por sus propias reglas.

TP4 · Criptografía y enmascaramiento

Proteger los datos sensibles, en tránsito y en reposo.

- **Hashing** de contraseñas y de tokens de sesión: nunca se guardan en texto plano.
- **Enmascaramiento dinámico (DDM)**: el comprador nunca ve el email real del vendedor; el dato real queda intacto y se ofusca al mostrarlo.
- **Cifrado en reposo (TDE a nivel columna)** de los datos de pago: en disco solo queda información cifrada.

Para qué: minimizar el daño ante una filtración — los datos robados no son utilizables.

TP5 · Programación defensiva contra inyección SQL

Que ninguna entrada del usuario altere una consulta.

Todas las consultas son parametrizadas (sin concatenar texto del usuario), con validación de entrada y manejo de errores que no revela detalles internos del motor.

Para qué: cerrar la puerta a la inyección SQL, una de las vulnerabilidades más comunes y peligrosas.

TP6 · Hardening (CIS / mínimo privilegio)

Reducir la superficie de ataque.

- La aplicación se conecta con un rol de **mínimo privilegio**, sin permisos de administración ni de borrado masivo.
- **Red mínima**: la base solo escucha en local, no expuesta a internet.
- El motor corre **sin privilegios de root**.

Para qué: si una credencial se compromete, el atacante hereda lo mínimo posible.

TP7 · Forensia (auditoría para investigación)

Usar la auditoría como base para el análisis forense.

Cada operación sobre las tablas críticas (publicaciones, compras, transferencias, disputas) queda registrada de forma **automática**, con **imagen previa y posterior** del dato, quién la hizo y cuándo. El registro es **inmutable** (no se puede editar ni borrar).

Caso forense principal: ante una transacción disputada, se reconstruye la cadena completa de hechos — quién publicó, quién compró, si se transfirió y si hubo modificaciones posteriores de precio o estado.

Para qué: garantizar no repudio y poder investigar incidentes después de que ocurren. Sin auditoría previa no hay forensia posible.

TP8 · Zero Trust / acceso Just-In-Time

Privilegios temporales, no permanentes.

Los moderadores no tienen acceso permanente a los datos privados de las disputas. Solo ven metadatos. Para ver el detalle deben solicitar una **elevación Just-In-Time**: con motivo obligatorio, acotada a una sola disputa y con **expiración automática**. Cada elevación queda auditada.

Para qué: aplicar Zero Trust — el acceso a datos sensibles se concede solo cuando se necesita, por el tiempo justo, y deja rastro.

Flujo de escrow (contexto del negocio)

Compra → el pago queda retenido (escrow) → el vendedor transfiere el ítem → el comprador confirma y se libera el pago.
Si hay conflicto: se abre una disputa → un moderador (con acceso Just-In-Time) la resuelve → reembolso al comprador o liberación al vendedor.
